

Engineering Decision Log — FREQUENCY (ProofForge Cyber)

Team ID: HM26-C3B5 | Track: Cybersecurity Talent & Evidence Pipeline | Format: 1-Page Engineering Audit

Q1. What approach did we take, and what did we reject?

We built an audited, deterministic evidence pipeline coupled with human reviewer authority and decoupled capability/confidence scoring.

Chosen Technical Pipeline: Candidate raw HTTP lab payloads, drag-and-drop vulnerability reports (PDF/DOCX), and timed 40-question answers → SHA-256 evidence collision hashing + 7-dimensional reviewer rubric scoring + server-side non-linear 9-domain DNA weighting → Ungameable Security DNA, sanitized recruiter reproduction cards, and synchronized virtual/on-spot interview invitations.

Rejected Alternative: We considered and prototyped an automated LLM vulnerability grading pipeline using dynamic prompt chains to ingest exploit payloads and output instant scores. This looked attractive initially because it promised zero-human latency, 24/7 continuous scaling, and eliminated human auditor scheduling bottlenecks.

Q2. Why did we reject it? What was the trade-off?

We rejected the automated LLM evaluator across four critical engineering dimensions:

1. Prompt Injection Vulnerability: Security exploit payloads inherently contain hostile characters (SQL quotes, script tags, serialized objects). Attackers trivially manipulate LLM evaluators via prompt injection within payloads to force automated 100/100 scores.

2. Hallucination & Defensibility: LLMs hallucinate CVE severity and cannot reliably distinguish legitimate authorization bypasses from superficial curl requests. In technical hiring, bad automated scores destroy employer trust.

3. Build Predictability in 72h: Non-deterministic prompt outputs make unit testing impossible; our relational schema and deterministic mathematical scoring engine delivered 100% reproducible, verifiable results.

4. Recruiter Trust: Hiring managers require verified reproduction curl commands and human auditor sign-off.

Accepted Trade-off: We knowingly accepted **asynchronous queue latency**. Candidates do not receive instant certification upon upload; they must wait for human auditor review and defense evaluation. We accepted this latency because compromised verification integrity is fatal.

Q3. What breaks at scale, and what is our architectural fix?

At institutional scale (50,000 active candidates and 1,000 reviewers during synchronized regional assessment drives), the first critical bottleneck is **database write contention and table scans during synchronized assessment submissions**. When 50,000 candidates finish a 20-minute timed test concurrently, 2,000,000 individual row inserts hit `assessment_results` while triggering unindexed SHA-256 collision scans over historical findings. Under default PostgreSQL pooling (100–200 connections), this causes transaction serialization deadlocks, connection pool exhaustion, and request latency exceeding 30 seconds.

Immediate Architectural Fix: (1) Decouple submission ingestion via an asynchronous Redis Streams message queue with Celery workers performing bulk inserts (5,000 rows/batch). (2) Deploy an in-memory Redis Bloom Filter (<15 MB RAM for 10M hashes at 0.1% false-positive rate) for O(1) duplicate collision pre-filtering prior to database writes. (3) Partition `submissions` and `assessment_results` by (candidate_id, section_id) with B-tree indexing on evidence hashes.